

Cyber Company AIMAS.
Security Assessment Report

Business Confidential

18/5/2026

Table of Contents

Contents

Assessment Overview	2
Assessment Components.....	3
OSINT	3
Internal Penetration Test.....	3
Finding Severity Ratings	4
Risk Factors	5
Scope.....	6
Executive Summary.....	7
Technical Findings	9

Assessment Overview

From May 18th, 2026 to May 19th, 2026, Cyber Company AIMAS commissioned a comprehensive penetration testing assessment against an internal hospital management system hosted within a local network environment. The methodologies used during this assessment were based on the National Institute of Standards and Technology (NIST) Special Publication (SP) 800-115 guidelines for penetration testing, combined with practical offensive security techniques to simulate realistic attack scenarios and identify security weaknesses within the target environment.

The testing process was conducted in multiple stages, focusing on Reconnaissance, Enumeration, Vulnerability Analysis, Exploitation, Privilege Escalation, and Reporting. Throughout the assessment, several vulnerabilities and misconfigurations were identified, including SQL Injection vulnerabilities within authentication portals, sensitive information disclosure through exposed directories and backup configurations, weak credential management practices, insecure password storage using MD5 hashes, and improper privilege assignments on the Linux operating system.

Successful exploitation of these vulnerabilities resulted in unauthorized access to nurse and administrator accounts, disclosure of sensitive backup information, SSH access to the target server, lateral movement between local users, and eventual root-level compromise of the system. The objective of this assessment was to evaluate the effectiveness of the existing security controls and provide insight into potential attack paths that could be leveraged by malicious actors against the organization's infrastructure.

Assessment Components

OSINT

The Open-Source Intelligence (OSINT) component of the assessment involved the systematic collection and analysis of information from publicly available sources. A range of digital tools were utilized to gather data from sources such as websites, forums, social media platforms, and databases. This data was analyzed to identify potential vulnerabilities and threat vectors, and to gain a deeper understanding of the security posture of Sedna Industries Inc.'s internal networks.

Internal Penetration Test

The internal penetration test was designed to simulate the actions of an attacker who had gained access to the internal network environment hosting the hospital management system. The assessment involved multiple phases to evaluate the security posture of the target machine and identify vulnerabilities that could lead to unauthorized access and privilege escalation.

Key stages of the internal penetration testing included:

1. **Vulnerability Scanning:** This phase focused on identifying active hosts and collecting technical information from the internal network environment. Network reconnaissance techniques were used to detect live systems and enumerate exposed services.
 - ✓ Tools such as **Netdiscover** were utilized to identify the target machine within the local network. After discovering the target IP address, Nmap was used to enumerate open ports and identify running services. Additional fingerprinting techniques were performed to identify the operating system, revealing a Linux-based environment exposing **SSH** and **HTTP** services that expanded the potential attack surface.
2. **Threat Modeling:** During this stage, the identified vulnerabilities and exposed services were analyzed to understand potential attack paths within the environment. The assessment focused on weaknesses in the web application authentication mechanisms, exposed directories, sensitive files, and insecure configurations that could lead to unauthorized access or privilege escalation.
3. **Exploitation:** Information gathered during the enumeration phase was leveraged to exploit multiple vulnerabilities within the target environment. SQL Injection vulnerabilities were identified in both the nurse and administrator authentication portals, allowing unauthorized access to privileged accounts. Additional enumeration revealed exposed backup information and sensitive credentials, which were then used to obtain SSH access to the target server. Furthermore, encrypted password hashes discovered on the system were analyzed and cracked using offline password-cracking techniques, resulting in valid user credentials.
4. **Post-Exploitation:** After gaining internal system access, post-exploitation activities focused on privilege escalation and sensitive data access. System enumeration was conducted to gather information about:

- Operating system and kernel details.
- Available user accounts and permissions.
- Exposed backup files and sensitive data.
- Misconfigured privilege assignments.

Based on the discovered information, a privilege escalation path was identified due to improper **sudo** permissions assigned to a local user account. Exploiting this misconfiguration allowed full root-level access to the target system and complete compromise of the environment.

5. **Reporting:** A comprehensive report was prepared to document the assessment methodology, vulnerabilities identified, exploitation process, impact of successful attacks, and recommended remediation steps to improve the overall security posture of the environment.

Finding Severity Ratings

Severity	CVSS v3 Score Ranges	Score Definition
Critical	9.0 - 10.0	Vulnerabilities that resulted in complete compromise of the target environment. During this assessment, chained vulnerabilities including SQL Injection, exposed credentials, and privilege misconfiguration allowed the attacker to gain full root-level access, resulting in total loss of confidentiality, integrity, and availability.
High	7.0 - 8.9	Vulnerabilities that allowed unauthorized access to privileged functionality or sensitive systems. In this assessment, SQL Injection vulnerabilities within the authentication portals enabled unauthorized access to nurse and administrator accounts, leading to significant compromise of the web application.
Medium	4.0 - 6.9	Vulnerabilities related to information disclosure and insecure configurations, including exposed directories, publicly accessible backup information, weak password hashing mechanisms (MD5), and sensitive data leakage through files such as robots.txt and backup configuration pages.
Low	0.1 - 3.9	Minor weaknesses and security misconfigurations that did not directly result in system compromise but increased the overall attack surface and risk to the environment.
Informational	0.0	Findings that did not present a direct security risk but provided useful technical information about the target environment, including operating system details, open ports, running services, network information, and accessible resources discovered during reconnaissance and enumeration phases.

Risk Factors

Risk factors identified during this assessment were evaluated using two primary criteria: Likelihood and Impact, based on real attack paths observed during the internal penetration test and successful exploitation of multiple vulnerabilities within the target environment.

Likelihood: represents the probability that a vulnerability could be successfully exploited under realistic conditions. In this assessment, likelihood was influenced by several contributing factors, including:

- The presence of publicly accessible services such as SSH and HTTP.
- Exposure of sensitive information through web application enumeration and directory discovery.
- Weak authentication mechanisms, including SQL Injection vulnerabilities in login portals.
- The presence of weak and crackable password hashes (e.g., MD5).
- Availability of known misconfigurations and predictable attack paths within the system.

Based on these conditions, several vulnerabilities were classified as High Likelihood, as exploitation required minimal technical complexity and no advanced defensive bypass techniques.

Impact: represents the potential severity of consequences following successful exploitation. In this assessment, impact was measured based on the level of system compromise achieved and the sensitivity of the affected assets.

Key impact considerations included:

- Unauthorized access to valid user accounts (nurse and admin roles).
- Successful privilege escalation to root, resulting in full system compromise.
- Exposure of sensitive system data, including backup files and internal configurations.
- Complete compromise of confidentiality, integrity, and availability of the target system.

Due to the successful escalation to root-level access, the overall impact of critical findings was classified as High.

By combining both Likelihood and Impact factors, an overall risk rating was assigned to each vulnerability. Findings demonstrating both high likelihood of exploitation and severe system-wide impact were prioritized as Critical Risks, requiring immediate remediation to prevent similar real-world exploitation scenarios.

Scope

Assessment Component	Focus Area(s)
Network Reconnaissance & Enumeration	Local network environment
Internal Penetration Test	192.168.1.0/24
Target Machine	192.168.1.3

Scope Exclusions

To ensure safe and controlled testing, the following activities were explicitly excluded from the assessment:

- No social engineering or human interaction-based attacks were performed.
- Denial of Service (DoS) and Distributed Denial of Service (DDoS) attacks were strictly out of scope.
- No testing was conducted outside the defined internal network range (192.168.1.0/24).
- No external systems or production environments were targeted during the assessment.

Method Allowances

Permission was granted to utilize standard and advanced penetration testing techniques within the defined scope, including:

- Active network scanning and service enumeration.
- Web application testing and vulnerability analysis.
- Exploitation of identified vulnerabilities within the target environment.
- Local privilege escalation techniques on compromised systems.

Executive Summary

Between May 18th, 2026 to May 19th, 2026, Cyber Company AIMAS conducted a controlled internal penetration testing assessment within a simulated hospital management system as part of a training and educational CTF environment. The objective of this engagement was to evaluate the security posture of an internally hosted application, identify exploitable vulnerabilities, and demonstrate realistic attack paths within a defined internal network scope.

The assessment focused on a single target machine located within the internal network range 192.168.1.0/24, specifically the host 192.168.1.3. All activities were conducted strictly within the authorized scope and limited to technical exploitation methods.

Throughout the engagement, multiple critical security weaknesses were identified across both the web application and underlying system layers. These vulnerabilities enabled an attacker to progress from initial network reconnaissance to unauthorized access of user and administrator accounts, followed by exposure of sensitive information, credential compromise, and eventual full root-level system takeover.

This report documents the methodologies, tools, and techniques used during the assessment, highlights key vulnerabilities discovered, and evaluates their associated risk levels based on likelihood and impact. The results clearly demonstrate how common issues such as SQL Injection, insecure information disclosure, weak credential storage, and system misconfigurations can be chained together to achieve complete system compromise.

Testing Summary

The assessment followed a structured penetration testing methodology aligned with industry best practices and included the use of the following techniques:

- Network discovery and host identification using active reconnaissance.
- Port scanning and service enumeration to identify exposed services.
- Web application enumeration and directory brute forcing.
- Information disclosure analysis through exposed files and configurations.
- Credential harvesting and offline password cracking.
- Exploitation of SQL Injection vulnerabilities in authentication systems.
- SSH access using recovered credentials.
- System enumeration and privilege escalation analysis.
- Local privilege escalation using misconfigured sudo permissions.

All testing activities were performed manually and validated through successful exploitation to ensure accuracy, reproducibility, and real-world applicability of the findings.

Assessor Notes & Primary Recommendations

The assessment indicates that the target environment reflects characteristics commonly associated with training environments and legacy system deployments, particularly those lacking modern security hardening and secure configuration practices.

The primary weaknesses identified include:

- Exposure of sensitive information through publicly accessible web resources.
- Weak credential storage and authentication protection mechanisms.
- Outdated operating system and kernel versions vulnerable to known local privilege escalation exploits.

Cyber Company AIMAS recommends implementing the following remediation actions:

- Enforce strong credential management policies and secure password hashing algorithms (e.g., bcrypt or Argon2).
- Restrict access to sensitive directories and files exposed via web services.
- Regularly update and patch operating systems, applications, and third-party services.
- Conduct periodic internal vulnerability assessments and penetration tests to proactively identify security weaknesses.

Addressing these issues will significantly reduce the risk of unauthorized access, data exposure, and privilege escalation within internal systems.

Key Strengths and Opportunities

Strengths:

- Clear network segmentation within a controlled internal environment.
- Limited number of exposed services reduced the initial attack surface.
- Ability to monitor and validate system activity during the assessment.

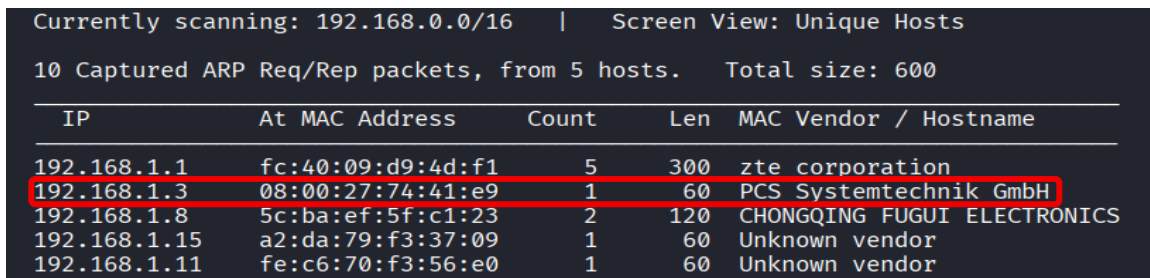
Opportunities for Improvement:

- Improve web server hardening and reduce information disclosure.
- Enforce least-privilege access across all system users and services.
- Implement continuous patch management and vulnerability scanning processes.

Technical Findings

Initial Network Discovery:

After connecting to the internal training network, active reconnaissance was performed to identify live hosts within the internal subnet. The goal of this phase was to map the attack surface and identify potential target systems.



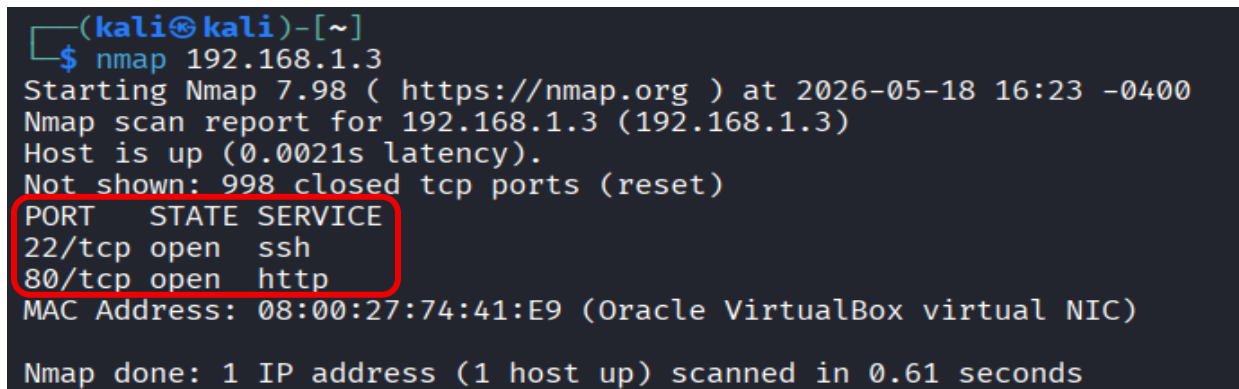
```
Currently scanning: 192.168.0.0/16 | Screen View: Unique Hosts
10 Captured ARP Req/Rep packets, from 5 hosts. Total size: 600
```

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.1.1	fc:40:09:d9:4d:f1	5	300	zte corporation
192.168.1.3	08:00:27:74:41:e9	1	60	PCS Systemtechnik GmbH
192.168.1.8	5c:ba:ef:5f:c1:23	2	120	CHONGQING FUGUI ELECTRONICS
192.168.1.15	a2:da:79:f3:37:09	1	60	Unknown vendor
192.168.1.11	fe:c6:70:f3:56:e0	1	60	Unknown vendor

Figure 1 – Network Discovery using Netdiscover - Shows the discovery of the target host 192.168.1.3 within the local network, including MAC address and vendor information obtained through ARP scanning.

Port and Service Enumeration:

Once the target host was identified, port scanning was conducted to determine exposed services and potential entry points.



```
(kali㉿kali)-[~]
$ nmap 192.168.1.3
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-18 16:23 -0400
Nmap scan report for 192.168.1.3 (192.168.1.3)
Host is up (0.0021s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:74:41:E9 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.61 seconds
```

Figure 2 - Port Scanning using Nmap - Displays the results of Nmap enumeration showing open ports on the target system, including SSH (22/tcp) and HTTP (80/tcp) services, along with OS detection results indicating a Linux-based system.

OS & Service Fingerprinting:

Further enumeration was performed to identify the operating system and service versions running on the target machine.

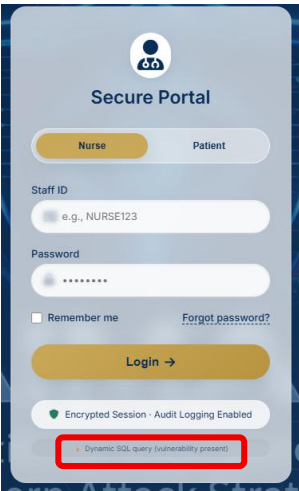
```
(kali㉿kali)-[~]
$ nmap -O 192.168.1.3
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-18 16:25 -0400
Nmap scan report for 192.168.1.3 (192.168.1.3)
Host is up (0.0019s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:74:41:E9 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.22 seconds
```

Figure 3 – Operating System Detection via Nmap - Shows OS fingerprinting results identifying a Linux kernel (4.x / 5.x) environment and confirming a VirtualBox-based virtual machine.

Web Application Discovery:

The target web application hosted on port 80 was manually inspected and analyzed for security weaknesses.

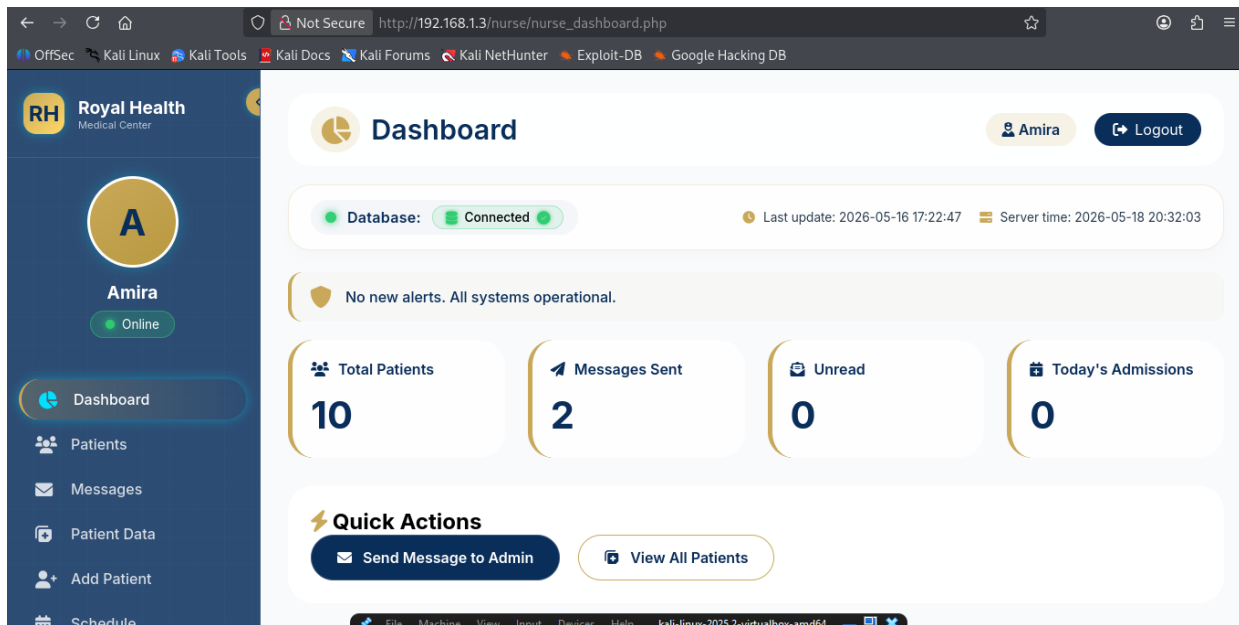


```
397 <div class="forgot-link" data-l18n="forgot_password">Forgot password?</div>
398 </div>
399 <button class="login-btn" type="submit" id="loginBtn">
400   <span data-l18n="login_button">Login</span>
401   <i class="fas fa-arrow-right" id="btnIcon"></i>
402 </button>
403 </form>
404 <div class="security-note">
405   <i class="fas fa-shield-alt"></i> <span data-l18n="security_text">Encrypted Session · Audit Logging Enabled</span>
406 </div>
407 <div class="sql-hint" title="SQL query built via concatenation: SELECT * FROM users WHERE username='<username>' AND password='<password>' AND role='<role>'>
408   ⚡ Dynamic SQL query (vulnerability present)
409 </div>
410 </div>
411 </div>
412 </script>
```

Figure 4 – Login Page (login.php) with SQL Injection Hint - Displays the login interface where insecure dynamic SQL query construction was observed, revealing potential SQL Injection vulnerability.

Authentication Bypass (SQL Injection):

During testing, SQL Injection was successfully used to bypass authentication controls.



Directory Enumeration:

Directory brute force techniques were used to identify hidden paths and sensitive resources.

```
(kali㉿kali)-[~]
$ dirb http://192.168.1.3/

_____|_____|
DIRB v2.22
By The Dark Raver
_____|_____|

START_TIME: Mon May 18 16:58:12 2026
URL_BASE: http://192.168.1.3/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

_____|_____|

GENERATED WORDS: 4612

-- Scanning URL: http://192.168.1.3/ --
=> DIRECTORY: http://192.168.1.3/admin/
+ http://192.168.1.3/admin.php (CODE:403|SIZE:23235)
=> DIRECTORY: http://192.168.1.3/errors/
+ http://192.168.1.3/robots.txt (CODE:200|SIZE:171)
+ http://192.168.1.3/server-status (CODE:403|SIZE:23235)
=> DIRECTORY: http://192.168.1.3/uploads/

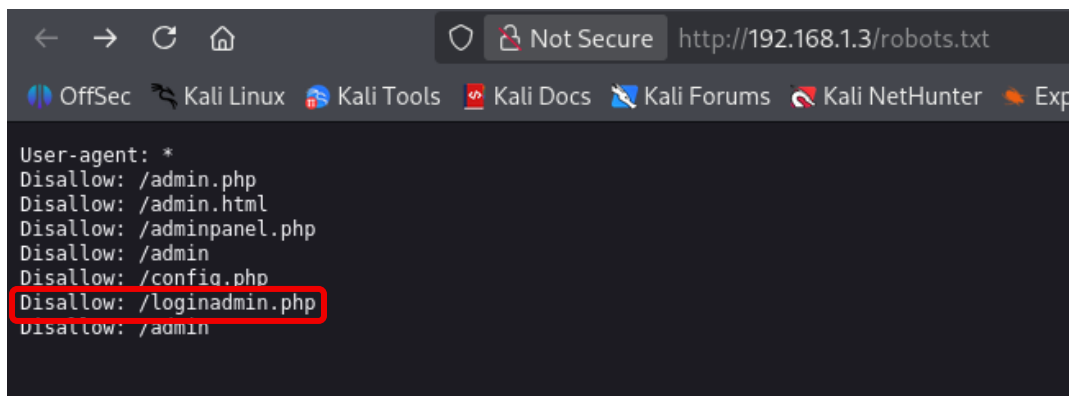
-- Entering directory: http://192.168.1.3/admin/ --
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

-- Entering directory: http://192.168.1.3/errors/ --
(!) WARNING: Directory IS LISTABLE. No need to scan it.
```

Figure 6 – Directory Enumeration using DIRB - Displays discovered directories such as /admin/, /uploads/, and /robots.txt, indicating exposed internal structure of the application.

Sensitive Information Disclosure:

Sensitive data was identified in publicly accessible files and directories.

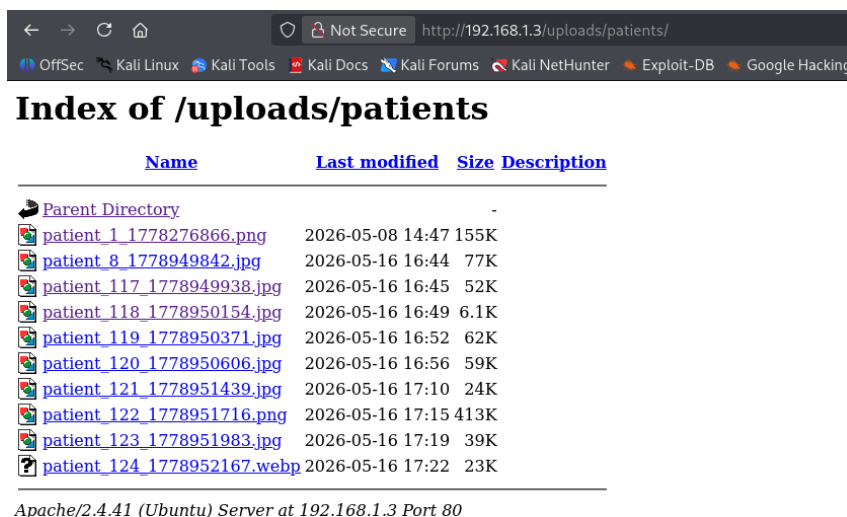


```
← → ↺ 🏠 Not Secure http://192.168.1.3/robots.txt
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exp
User-agent: *
Disallow: /admin.php
Disallow: /admin.html
Disallow: /adminpanel.php
Disallow: /admin
Disallow: /config.php
Disallow: /loginadmin.php
Disallow: /admin
```

Figure 7 – robots.txt and Uploads Directory Exposure - Shows disallowed administrative paths and exposed file storage containing sensitive medical-related data.



Figure 8 – XSS – Shat messes nurse – Admin.



Name	Last modified	Size	Description
Parent Directory	-	-	-
patient_1_1778276866.png	2026-05-08 14:47	155K	
patient_8_1778949842.jpg	2026-05-16 16:44	77K	
patient_117_1778949938.jpg	2026-05-16 16:45	52K	
patient_118_1778950154.jpg	2026-05-16 16:49	6.1K	
patient_119_1778950371.jpg	2026-05-16 16:52	62K	
patient_120_1778950606.jpg	2026-05-16 16:56	59K	
patient_121_1778951439.jpg	2026-05-16 17:10	24K	
patient_122_1778951716.png	2026-05-16 17:15	413K	
patient_123_1778951983.jpg	2026-05-16 17:19	39K	
patient_124_1778952167.webp	2026-05-16 17:22	23K	

Apache/2.4.41 (Ubuntu) Server at 192.168.1.3 Port 80

Figure 9 – Where to store photos of all patients.

Admin Panel Access:

Further exploitation of SQL Injection led to administrator-level access.

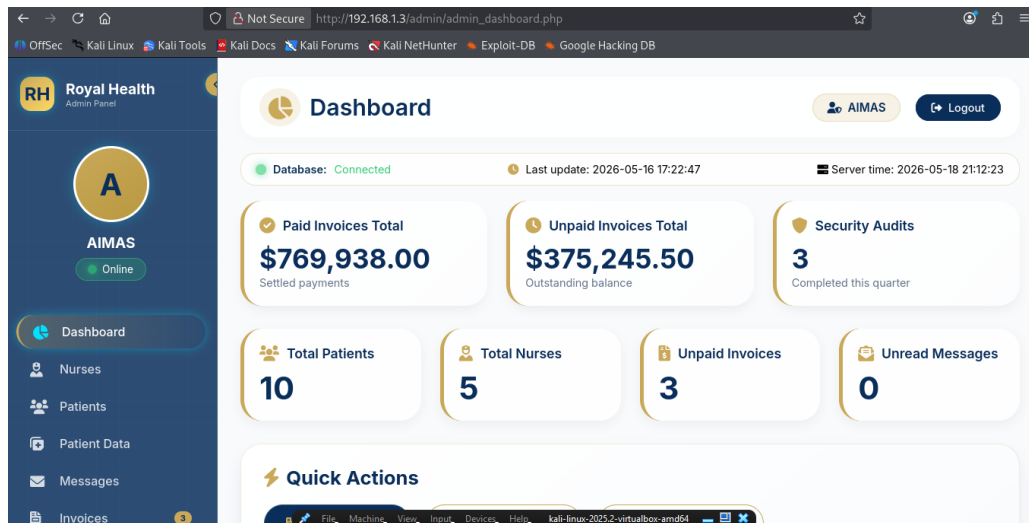


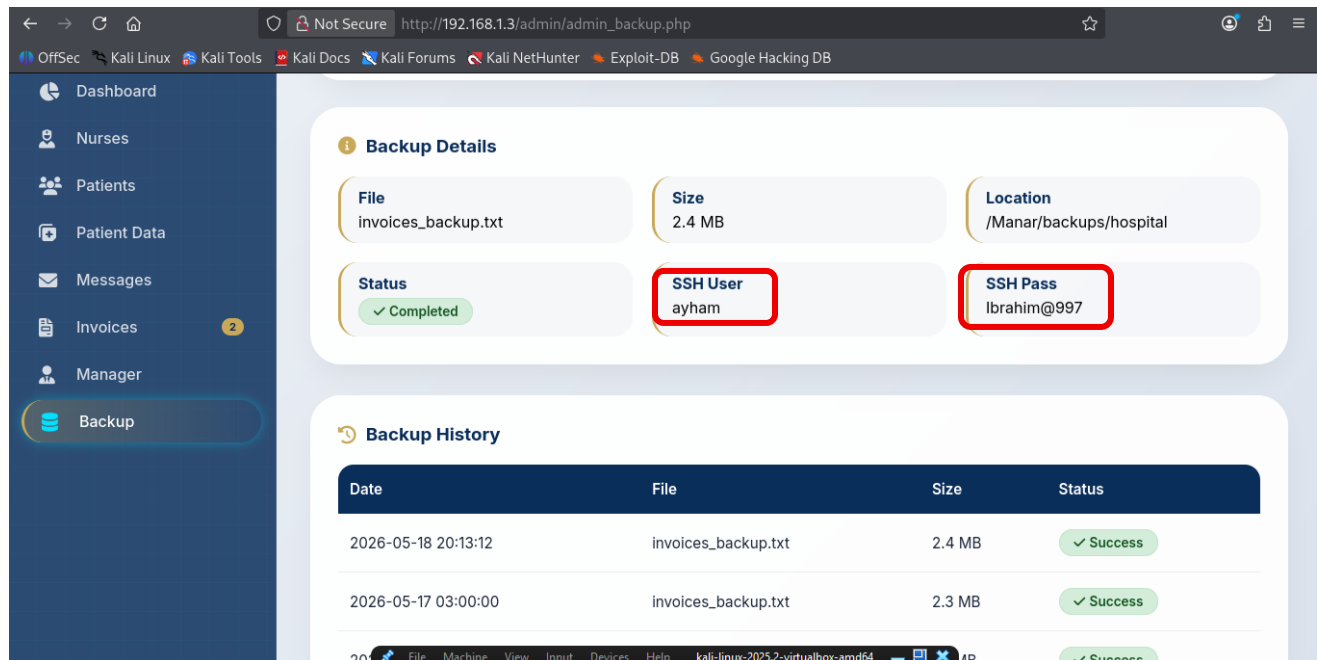
Figure 10 – Admin Dashboard Access - Shows successful login into administrator panel with full control over invoices and system data.

All Invoices						
#	Patient	Amount (\$)	Status	Description	Date	Actions
#16	Cyber	\$300,000.00	Unpaid	Consultation + Labs	May 16, 2026	Edit Delete
#15	Nadia Ramzi Hanna	\$75,000.00	Unpaid	Pelvic ultrasound + hormonal profile	May 16, 2026	Edit Delete
#14	Ibrahim Adel Fawzi	\$167,000.00	Paid	Rheumatology workup + joint X-rays	May 16, 2026	Edit Delete
#13	Huda Mahmoud Abdelrahman	\$140,000.00	Paid	Neurology consultation + MRI	May 16, 2026	Edit Delete
#	Patient	Amount (\$)	Status	Description	Date	Actions
#15	Nadia Ramzi Hanna	\$75,000.00	Unpaid	Pelvic ultrasound + hormonal profile	May 16, 2026	Edit Delete
#14	Ibrahim Adel Fawzi	\$167,000.00	Paid	Rheumatology workup + joint X-rays	May 16, 2026	Edit Delete
#13	Huda Mahmoud Abdelrahman	\$140,000.00	Paid	Neurology consultation + MRI	May 16, 2026	Edit Delete
#12	Layla Rashed Ahmed	\$280,000.00	Paid	Pulmonary function test + allergy	May 16, 2026	Edit Delete

Figure 11 – Delete the invoice.

SSH Access via Credential Disclosure:

Sensitive backup configuration exposed SSH credentials used to access the system.



```
New release '22.04.5 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Last login: Tue May 19 21:12:07 2026
ayham@ctf-zero-day-legacy:~$ ls
crack-Manar-hash.txt  notes.txt  www
ayham@ctf-zero-day-legacy:~$ cat notes.txt
The backup script is in user2 "Manar"
/Manar/backups/hospital/invoices_backup.txt
ayham@ctf-zero-day-legacy:~$
```

Figure 12 – SSH Access to Target System - Shows successful login via SSH using credentials obtained from the backup page.

Privilege Escalation:

A password hash was discovered and successfully cracked offline, leading to user privilege escalation.

```
ayham@ctf-zero-day-legacy:~$ cat crack-Manar-hash.txt
985745d2d51774afb8caabeacf1c998a
ayham@ctf-zero-day-legacy:~$
```

```
plaintext: Salsbeel@2004
MD5: 985745d2d51774afb8caabeacf1c998a
```

Figure 13 – Hash Cracking and User Access - Displays cracked MD5 hash and successful switch to user Manar.

Switch account:

```
ayham@ctf-zero-day-legacy:~$ su - Manar
Password:
Manar@ctf-zero-day-legacy:~$ ls
backups Desktop Documents Downloads Music Pictures Public team Videos
Manar@ctf-zero-day-legacy:~$

Manar@ctf-zero-day-legacy:~$ ls
backups Desktop Documents Downloads Music note.txt Pictures Public team Videos
Manar@ctf-zero-day-legacy:~$ cat note.txt
Misconfiguration: User Manar has full sudo rights due to administrative oversight.
Manar@ctf-zero-day-legacy:~$ cd backups/
Manar@ctf-zero-day-legacy:~/backups$ ls
hospital
Manar@ctf-zero-day-legacy:~/backups$ cd hospital/
Manar@ctf-zero-day-legacy:~/backups/hospital$ ls
invoices_backup.txt
Manar@ctf-zero-day-legacy:~/backups/hospital$ cat invoices_backup.txt
cat: invoices_backup.txt: Permission denied
Manar@ctf-zero-day-legacy:~/backups/hospital$ sudo cat invoices_backup.txt

  🔥 YOU HAVE BEEN PWNED BY ZERO-DAY LEGACY TEAM 🔥

  "We don't break systems – we expose their fragile souls."

  This hospital's invoice backup is now UNDER OUR CONTROL.
  Your security was a castle of sand – we washed it away.

  🧨 Ayham | Ibrahim | Manar | Amira | Salsabeel 🧨

  CTF SOLVED! Congratulations, you've reached the root.
  But remember: with great power comes great responsibility.

Manar@ctf-zero-day-legacy:~/backups/hospital$
```

Figure 14 – Privilege escalation was achieved due to misconfigured sudo permissions.

Root Compromise:

Privilege escalation was achieved due to misconfigured sudo permissions.

```
Manar@ctf-zero-day-legacy:~/backups/hospital$ su -
Password:
root@ctf-zero-day-legacy:~# ls
snap
root@ctf-zero-day-legacy:~# id
uid=0(root) gid=0(root) groups=0(root)
root@ctf-zero-day-legacy:~# whoami
root
root@ctf-zero-day-legacy:~#
```

Figure 15 – Root Access Obtained - Shows full root access after executing privileged commands, confirming complete system compromise.